

Reporte Ejecutivo de Gestión de Riesgos

Clínica Demo — Dirigido al Directorio — Preparado por el Responsable de Seguridad de la Información

Resumen ejecutivo

A raíz de la reciente auditoría externa, que identificó debilidades en la gestión de riesgos de la institución, se realizó un relevamiento inicial y se conformó el primer registro formal de riesgos de la clínica utilizando la herramienta SimpleRisk. Se identificaron y evaluaron 7 riesgos específicos del contexto de la organización, abarcando aspectos de confidencialidad, integridad, disponibilidad, cumplimiento legal y operativos.

Del total de riesgos relevados, 5 fueron clasificados como de nivel **Alto**, 1 como **Medio** y 1 como **Bajo**. Los riesgos de nivel alto se concentran principalmente en prácticas informales del personal (uso de mensajería personal, credenciales compartidas), en la falta de validación de continuidad operativa (backups sin prueba de restauración) y en la ausencia de marcos contractuales formales con proveedores externos. Ninguno de los riesgos relevados fue clasificado como catastrófico en su nivel global, aunque uno de ellos presenta el máximo impacto posible en caso de materializarse.

Se definieron 3 planes de acción concretos para atender los riesgos más críticos, con responsables, plazos y presupuestos estimados asignados. Este reporte resume los hallazgos principales y las recomendaciones prioritarias para la toma de decisiones del Directorio.

Top 5 riesgos por nivel

#	Riesgo	Categoría	Nivel
2	Backups del sistema de Historia Clínica Electrónica sin prueba de restauración	Disponibilidad	Alto
6	Falta de acuerdos de confidencialidad (NDA) con proveedores externos de TI	Legal	Alto
5	Uso de credenciales compartidas en guardias nocturnas del sistema de HCE	Integridad	Alto
1	Uso de mensajería personal (WhatsApp) para compartir información clínica	Confidencialidad	Alto
3	Doble carga manual de prestaciones entre HCE y facturación a obras sociales	Integridad	Alto

Nota: se ordenan de mayor a menor impacto potencial dentro del nivel Alto. El riesgo de backups sin prueba de restauración presenta el mayor impacto posible (afecta la continuidad de la atención médica), aunque su probabilidad es media.

Estado de los planes de acción

Plan de acción	Riesgo asoc.	Responsable	Vence	Presupuesto	Estado
Pruebas trimestrales de restauración de backups	R2	Jefe de IT / Sistemas	60 días	USD 500-1000	Pendiente
Baja de usuario genérico y altas individuales en guardia	R5	Jefe de IT / Sistemas	45 días	USD 300-600	Pendiente
Formalización contractual con proveedores de TI	R6	Resp. Seguridad de la Información	90 días	USD 800-1500	Pendiente

Los tres planes se encuentran en estado inicial "Pendiente", a la espera de aprobación de presupuesto y asignación formal de recursos por parte del Directorio.

Recomendaciones prioritarias

- Aprobar y asignar presupuesto a los 3 planes de acción propuestos, priorizando el plan de pruebas de restauración de backups por su impacto potencial sobre la continuidad de la atención médica.

- Formalizar una política institucional de comunicación clínica que reemplace el uso de aplicaciones de mensajería personal para el intercambio de información de pacientes entre profesionales.
- Exigir la firma de acuerdos de confidencialidad y cláusulas de protección de datos personales a todo proveedor externo con acceso a sistemas o información sensible, como condición para mantener el vínculo.
- Establecer un cronograma de revisión periódica del registro de riesgos (por ejemplo, semestral), de forma de dar continuidad al proceso iniciado y no depender de auditorías externas para detectar nuevas debilidades.
- Formalizar la designación de un responsable de seguridad de la información con dedicación permanente a esta función, dado que la ausencia de un rol de este tipo fue una de las causas raíz identificadas en los hallazgos de la auditoría externa.